

GUÍA METODOLÓGICA DETALLADA

Encuesta MSS — Indicadores y Métricas de Servicios de Seguridad Gestionados

Fundamentos, Diseño, Aplicación y Análisis

Versión 1.0 — Abril 2026

"Una encuesta sin metodología es un sondeo de opinión con ínfulas científicas. Una metodología sin encuesta es una obra de teatro sin público. El éxito de esta herramienta reside en su matrimonio."

1. FUNDAMENTOS EPISTEMOLÓGICOS Y MARCO TEÓRICO

1.1 Justificación de la Herramienta

Esta encuesta responde a una necesidad documentada en múltiples marcos de referencia internacionales: la ausencia de herramientas de diagnóstico estandarizadas para la medición de la madurez en Servicios de Seguridad Gestionados (MSS) en el contexto regulatorio español y europeo.

El análisis de mercado MSS de ENISA (junio 2025) identificó que solo el 24% de las organizaciones que contratan MSS logran negociar la selección y parametrización de métricas específicas en sus SLAs, mientras que del lado de los proveedores ese porcentaje cae a nivel estadísticamente insignificante. Esta asimetría de información entre demanda y oferta genera un mercado en el que los incentivos para la mejora son débiles y la comparabilidad entre proveedores es prácticamente inexistente.

El ENISA Cybersecurity Market Analysis Framework (ECSMAF) V3.0 (marzo 2026), desarrollado conjuntamente con la Università Bocconi, establece las bases metodológicas para un observatorio permanente del mercado MSS en la UE, con modelo federado de análisis a escala nacional. Esta encuesta es coherente con ese marco.

1.2 Bases Normativas de Referencia

La encuesta se fundamenta en los siguientes marcos normativos y de buenas prácticas:

Marco	Ámbito	Elementos incorporados en la encuesta
Reglamento (UE) 2025/37	Definición formal de MSS	Taxonomía de servicios, requisitos de certificación EUMSS
Directiva NIS2 (UE) 2022/2555	Seguridad de redes y sistemas	Plazos de notificación, requisitos de gobernanza, formación directiva
Anteproyecto Ley Gobernanza Ciberseguridad (España, enero 2025)	Marco nacional	CNCS, clasificación entidades, obligaciones
ENS RD 311/2022	Administración Pública española	Categorías, controles, auditoría
DORA (UE) 2022/2554	Sector financiero	Resiliencia operativa digital, gestión de riesgos TIC de terceros
ISO/IEC 27001:2022	SGSI	Controles de seguridad, métricas de gestión
ISO/IEC 27004:2016	Monitorización y medición	Framework de métricas SGSI
NIST Cybersecurity Framework 2.0	Marco universal	Funciones: Govern, Identify, Protect, Detect, Respond, Recover
NIST SP 800-55	Métricas de seguridad	Taxonomía de indicadores de rendimiento
ENISA MSS Market Analysis (junio 2025)	Mercado europeo MSS	Brechas de oferta-demanda, indicadores de mercado
ENISA ECSMAF V3.0 (marzo 2026)	Metodología análisis mercado	Dimensiones de análisis, encuesta federada
ENISA Threat Landscape 2025	Paisaje de amenazas	Vectores, sectores objetivo, estadísticas de incidentes
Balance INCIBE 2025	Contexto nacional	Estadísticas nacionales de incidentes
CAS Research Paper on Cyber Risk (junio 2025)	Actuarial	CRQ, cuantificación, escenarios de estrés

2. DISEÑO METODOLÓGICO DE LA ENCUESTA

2.1 Tipo de Instrumento

La encuesta es un instrumento de **diagnóstico mixto** que combina:

- Preguntas de opción múltiple única (P0.1, P0.2...): Para datos de perfil y categorización unívoca.
- Preguntas de opción múltiple múltiple (P2.4, P6.1...): Para capturar la diversidad de prácticas en paralelo.
- Escalas de autoevaluación de 5 niveles (P2.7, P12.1): Alineadas con el modelo CMM (Capability Maturity Model) aplicado a SOC y MSS.
- Preguntas de texto libre (P12.4): Para capturar matices cualitativos no anticipados.
- Preguntas de rango cuantitativo (P3.2, P3.4, P3.5...): Para obtener aproximaciones a métricas reales incluso cuando no existe medición formal.

2.2 Estructura de Bloques y Lógica de Navegación

La encuesta se organiza en 13 bloques (B0 a B12) con lógica de salto condicional:

B0 (Perfil) → TODOS los respondentes
B1 (Gobierno) → TODOS los respondentes
B2 (Modelo MSS) → TODOS los respondentes
B3 (Indicadores operativos) → Si P2.1 ≠ "Sin modelo definido"
B4 (Cumplimiento) → TODOS los respondentes
B5 (Resiliencia) → TODOS los respondentes
B6 (Tecnología) → TODOS los respondentes
B7 (Capital humano) → TODOS los respondentes
B8 (CTI) → Si P2.1 incluye MSS externo o SOC interno
B9 (Impacto financiero) → TODOS los respondentes
B10 (Tecnologías emergentes) → TODOS los respondentes
B11 (Soberanía digital) → Si P0.3 = Nacional/Europeo/Global
B12 (Evaluación global) → TODOS los respondentes

Total de preguntas: 55 preguntas principales + subítems opcionales.

Preguntas núcleo (no omisibles): 28 preguntas marcadas como obligatorias.

Tiempo estimado de respuesta: 25-45 minutos.

2.3 Validez y Fiabilidad del Instrumento

Validez de contenido: El instrumento fue diseñado mediante el proceso de revisión de literatura de los marcos normativos y estudios de referencia listados en la Sección 1.2. Cada pregunta mapa a uno o más requisitos normativos documentados (ver documento (d) Mapeo Normativo).

Validez de constructo: La agrupación en 5 pilares del Índice IGM-MSS (ver Sección 4) refleja la estructura del NIST CSF 2.0 y los dominios de análisis del ECSMAF V3.0 de ENISA.

Fiabilidad test-retest: Se recomienda la aplicación del coeficiente alpha de Cronbach para bloques de escala (B1, B6, B7) una vez acumulados al menos 30 respondentes.

Sesgo de respuesta social: El diseño de opciones incluye deliberadamente respuestas «honestas pero desfavorables» descritas con lenguaje literario no peyorativo, para reducir el sesgo hacia respuestas socialmente deseables. Ejemplo: *"Confiamos en la resiliencia natural de la organización, que en los últimos años ha demostrado ser sorprendentemente frágil"* (P5.1).

3. PERFIL DE RESPONDENTES Y PROTOCOLO DE ADMINISTRACIÓN

3.1 Respondentes Objetivo

La encuesta está diseñada para ser respondida por **uno o varios de los siguientes perfiles** en cada organización:

Perfil	Bloques de máxima relevancia	Conocimiento requerido
CISO / Responsable de Seguridad	Todos (B0–B12)	Alto en todos los bloques
CTO / CIO	B0, B1, B2, B6, B7, B9, B12	Alto técnico, medio regulatorio
Director/a de Riesgos / Compliance	B0, B1, B4, B5, B9, B11, B12	Alto normativo, medio técnico
Responsable de SOC	B3, B6, B7, B8, B10	Alto técnico-operativo
Gestor/a de contratos MSS	B2, B3, B4	Medio-alto contractual
Director/a General / COO	B0, B1, B9, B12	Estratégico, no técnico

Recomendación: Para organizaciones de más de 250 empleados, se sugiere aplicación multi-respondente con la herramienta de reconciliación de respuestas incluida en la Plantilla Excel (documento e).

3.2 Modalidades de Administración

Modalidad A — Autoaplicación digital:

- Formulario web (Google Forms, Microsoft Forms, Typeform o equivalente) con lógica de salto condicional.
- Recomendada para estudios sectoriales y benchmarking.
- Permite anonimización y exportación automática a CSV para procesamiento en la Plantilla Excel.

Modalidad B — Entrevista guiada (presencial o videoconferencia):

- Aplicación por consultor o investigador entrenado.
- Permite explorar respuestas en profundidad y reducir el sesgo de incomprensión.
- Recomendada para organizaciones de menos de 50 empleados donde el perfil CISO es inexistente.
- Duración estimada: 60-90 minutos.

Modalidad C — Taller de diagnóstico grupal:

- Sesión de trabajo con múltiples responsables de la organización.
- Facilita el consenso en respuestas donde los perfiles tienen perspectivas divergentes.
- Especialmente útil para preguntas de B12 (evaluación estratégica).
- Requiere facilitador externo para evitar sesgos de autoridad jerárquica.

3.3 Protocolo de Anonimización y Protección de Datos

La recogida y procesamiento de datos cumple con:

- **RGPD** (Reglamento UE 2016/679): Base legal de consentimiento informado o interés legítimo en

estudios sectoriales.

- **LOPDGDD** (Ley Orgánica 3/2018): Normativa española de protección de datos personales.

Principios aplicados:

1. **Minimización:** Solo se recogen datos necesarios para el cálculo del IGM-MSS y benchmarking sectorial.
2. **Seudonimización:** Los identificadores organizacionales se sustituyen por códigos internos antes del análisis.
3. **Separación:** Los datos de contacto se almacenan separados de las respuestas.
4. **Derecho de acceso y rectificación:** Disponible durante los 12 meses posteriores a la respuesta.

4. EL ÍNDICE DE MADUREZ GLOBAL MSS (IGM-MSS)

4.1 Definición y Estructura

El IGM-MSS es un indicador compuesto que sintetiza el nivel de madurez de la organización en ciberseguridad gestionada en una escala de 0 a 100 puntos, articulada en 5 pilares:

Pilar	Preguntas asociadas	Ponderación	Descripción
P-I: Gobernanza y Estrategia	B1, B2 (parcial)	20%	Estructura de gobierno, estrategia, presupuesto, cultura
P-II: Detección y Respuesta Operativa	B3, B6 (parcial)	25%	MTTD, MTTC, MTTR, FPR, cobertura de activos
P-III: Cumplimiento y Gestión de Riesgos	B4, B11	20%	Cumplimiento regulatorio, TPRM, soberanía digital
P-IV: Resiliencia y Continuidad	B5, B7	15%	BCP, simulacros, recuperación, capital humano
P-V: Tecnología y Madurez Emergente	B6, B8, B9, B10	20%	CTI, PQC, IA, ROSI, ciberseguro

Puntuación total IGM-MSS:

$$\text{IGM-MSS} = (\text{P-I} \times 0.20) + (\text{P-II} \times 0.25) + (\text{P-III} \times 0.20) + (\text{P-IV} \times 0.15) + (\text{P-V} \times 0.20)$$

Escala de interpretación:

Rango IGM-MSS	Nivel de Madurez	Denominación CMM-SOC
0 - 20	Inicial	Nivel 1: Ad Hoc
21 - 40	Gestionado básico	Nivel 2: Reactivo
41 - 60	Definido	Nivel 3: Proactivo
61 - 80	Gestionado cuantitativamente	Nivel 4: Analítico
81 - 100	Optimizado	Nivel 5: Estratégico

4.2 Sistema de Puntuación por Pregunta

Cada respuesta recibe una puntuación entre 0 y 4 (normalizada al máximo del pilar correspondiente):

- Puntuación 4: Respuesta que refleja el nivel de excelencia o mejores prácticas internacionales.
- Puntuación 3: Respuesta que refleja práctica avanzada por encima de la media del mercado.
- Puntuación 2: Respuesta que refleja práctica aceptable alineada con requisitos mínimos.
- Puntuación 1: Respuesta que refleja práctica insuficiente con riesgos identificados.
- Puntuación 0: Respuesta que refleja ausencia de práctica o riesgo crítico.
- N/A: No aplica; excluida del cálculo del pilar correspondiente con redistribución proporcional.

La Plantilla Excel (documento e) automatiza este cálculo con tablas de conversión pregunta-a-puntuación.

4.3 Benchmarks de Referencia

Los siguientes benchmarks están disponibles para el posicionamiento comparativo:

Benchmark	Fuente	Disponibilidad
Media sectorial España (por CNAE)	INCIBE Balance 2025 / Aon España 2025	Incluido en informe generado
Media UE por sector	ENISA ECSMAF V3.0 / MSS Market Analysis 2025	Incluido en informe generado
Percentiles por tamaño organizacional	Agregado de respuestas anónimas acumuladas	Disponible tras N>30 respuestas
Benchmark de entidades NIS2 esenciales	ENISA NIS Investment Report	Referencia externa

5. ANÁLISIS CUALITATIVO Y TRIANGULACIÓN

5.1 Codificación de Respuestas Abiertas (P12.4)

Las respuestas del campo abierto P12.4 se analizan mediante:

1. **Análisis temático inductivo** (Braun & Clarke, 2006): Identificación de temas recurrentes sin categorías predefinidas.
2. **Análisis de sentimiento**: Clasificación positivo/neutro/negativo respecto a la postura de seguridad.
3. **Extracción de barreras emergentes**: Identificación de obstáculos no contemplados en B12.2.

5.2 Triangulación Multi-Respondente

Para organizaciones donde varios perfiles completan la encuesta, se aplica el siguiente protocolo:

- Convergencia (≤ 1 nivel de diferencia en escala 5): Se adopta la media ponderada.
- Divergencia moderada (2 niveles): Se registra la divergencia como indicador de "desalineación de percepción" entre niveles de la organización.
- Divergencia severa (≥ 3 niveles): Se identifica como "brecha de gobernanza" y se reporta como hallazgo prioritario en el informe.

5.3 Análisis Longitudinal

Se recomienda la reaplicación de la encuesta:

- **A los 6 meses:** Verificación de planes de mejora iniciados.
- **Al año:** Medición de evolución del IGM-MSS y recalibración de benchmarks.
- **Ante cambios regulatorios significativos:** Transposición NIS2, entrada en vigor EUMSS, etc.

6. LIMITACIONES Y MITIGACIONES

Limitación	Naturaleza	Estrategia de mitigación
Sesgo de deseabilidad social	Respondentes sobrevaloran prácticas	Opciones con lenguaje literario honesto; anonimización garantizada
Desconocimiento de métricas específicas	CISO/CTO no conoce valores reales	Opciones de «No disponemos de datos» sin penalización implícita
Variabilidad en definición de «incidente»	Distintas culturas organizacionales	Definiciones operativas incluidas en notas al pie de cada pregunta
Autoevaluación sin verificación externa	Respuesta puede no reflejar realidad	Triangulación multi-respondente y correlación con datos externos
Sesgos de sector y tamaño	Benchmarks pueden no ser representativos	Estratificación por sector y tamaño en análisis comparativo
Asimetría de información en contratos MSS	Gestores desconocen detalles SLA	Se recomienda revisión previa del contrato antes de responder B2

7. PROTOCOLO DE PRESENTACIÓN DE RESULTADOS

7.1 Estructura del Informe de Retorno al Respondente

El informe de resultados generado por la Plantilla Excel (documento e) incluye:

1. Resumen ejecutivo (1 página): IGM-MSS global, fortalezas top-3 y brechas prioritarias.
2. Diagnóstico por pilares (5 páginas): Puntuación, interpretación y benchmark sectorial para cada pilar P-I a P-V.
3. Hoja de ruta de mejora (2 páginas): Acciones prioritarias ordenadas por impacto/esfuerzo, con mapeo a requisitos normativos.
4. Comparativa sectorial (1 página): Posicionamiento percentil en el sector y en el mercado nacional.
5. Recomendaciones MSS (1 página): Indicadores a incluir en próximas negociaciones de SLA.

7.2 Indicadores de Calidad de Respuesta

Antes de calcular el IGM-MSS, se verifica la calidad de la respuesta:

- **Tasa de completitud:** $\geq 80\%$ de preguntas respondidas (mínimo para cálculo válido).
- **Coherencia interna:** Verificación de inconsistencias lógicas (ej: P2.5 = «No proveedor MSS» + P2.6 con métricas marcadas).
- **Tiempo de respuesta:** Respuestas completadas en menos de 3 minutos se marcan como «respuesta rápida no analítica» para revisión manual.

8. GLOSARIO METODOLÓGICO

Término	Definición en contexto MSS
MTTD	Mean Time to Detect: tiempo medio desde el inicio de actividad maliciosa hasta su identificación por el sistema de detección
MTTA	Mean Time to Acknowledge: tiempo desde la creación de una alerta hasta que un analista la gestiona activamente
MTTC	Mean Time to Contain: tiempo desde la detección hasta el aislamiento efectivo de la amenaza
MTTR	Mean Time to Respond/Recover: tiempo desde la detección hasta la remediación completa y retorno a operaciones
FPR	False Positive Rate: tasa de alertas que resultan no ser incidentes reales
ACR	Asset Coverage Ratio: porcentaje del patrimonio digital monitorizado en tiempo real
ROSI	Return on Security Investment: retorno económico de la inversión en seguridad
CRQ	Cyber Risk Quantification: cuantificación probabilística del riesgo ciber con modelos actuariales
IGM-MSS	Índice de Madurez Global MSS: indicador compuesto de 0-100 puntos resultado de esta encuesta
CTI	Cyber Threat Intelligence: inteligencia de amenazas, información contextualizada sobre actores, TTP y IOCs
PQC	Post-Quantum Cryptography: criptografía resistente a ataques de computadoras cuánticas
TPRM	Third Party Risk Management: gestión formal del riesgo de seguridad de proveedores y terceros
UEBA	User and Entity Behavior Analytics: analítica de comportamiento de usuarios y entidades para detección de anomalías
TTP	Tactics, Techniques and Procedures: tácticas, técnicas y procedimientos de los actores de amenaza
IOC	Indicator of Compromise: indicador de compromiso, artefacto observable que indica actividad maliciosa
BCP	Business Continuity Plan: plan de continuidad de negocio ante interrupciones graves
ENS	Esquema Nacional de Seguridad (RD 311/2022): marco de seguridad para la Administración Pública española

NIS2	Network and Information Security Directive 2 (UE 2022/2555): directiva de seguridad de redes y sistemas de información
DORA	Digital Operational Resilience Act (UE 2022/2554): reglamento de resiliencia operativa digital para el sector financiero
EUMSS	European Managed Security Services (esquema de certificación europeo MSS, en desarrollo por ENISA desde 2025)
ECSMAF	ENISA Cybersecurity Market Analysis Framework (metodología V3.0, marzo 2026)

Guía Metodológica — Versión 1.0 · Abril 2026

Basada en: ENISA ECSMAF V3.0, ENISA MSS Market Analysis 2025, NIST SP 800-55, ISO/IEC 27004, CMM-SOC, Braun & Clarke (2006)